
Informe de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Alumna: **Chiara Hernandez**

Username de TryHackMe: **chiarahernandezp**

Índice

1. Datos generales	2
2. Pre-pentesting	2
3. Durante: Hallazgos por fase	3
3.1. Hallazgos — Basic Pentesting (Núcleo obligatorio)	3
3.2. Hallazgos — Vulnversity (Sala de elección)	5
4. Resumen ejecutivo de hallazgos	5
5. Post-pentesting: Recomendaciones	5
6. Protocolo de contingencia	6
7. Anexos	7
8. Fuentes y bibliografía	8

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Chiara Hernandez
DNI	45967321
Username TryHackMe	chiarahernandezp
Email institucional	hernandezchiara@uch.edu
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	hernandez-chiara
Fecha de inicio	2026-10-01
Fecha de cierre	2026-10-08

2. Pre-pentesting

Alcance del trabajo

El alcance de este trabajo se limita exclusivamente a los entornos de laboratorio provistos por la plataforma TryHackMe (TryHackMe.com), concretamente a las máquinas virtuales asignadas dentro de las salas *Pentesting Fundamentals*, *Basic Pentesting* y la sala de elección de Nivel 2 (*Vulniversity*). Dentro del alcance se incluyen los servicios expuestos por dichas máquinas (puertos TCP/UDP, servicios web, SMB, SSH, FTP, proxies, etc.) accedidos a través de la red VPN de TryHackMe. Quedan fuera de alcance: cualquier sistema, red o dispositivo que no pertenezca a la infraestructura de laboratorio de TryHackMe, incluyendo redes propias, de la facultad o de terceros.

Reglas de Enfrentamiento (ROE)

- Las pruebas se realizan únicamente contra la IP asignada dinámicamente por TryHackMe al desplegar cada máquina de laboratorio.
- Está prohibido aplicar las técnicas aprendidas contra sistemas reales o productivos fuera del entorno de laboratorio.
- No se realizan ataques de denegación de servicio (DoS) ni pruebas que puedan degradar la disponibilidad del servicio de TryHackMe para otros usuarios.
- Toda la actividad se documenta en bitácora (comandos ejecutados) y evidencias (capturas de pantalla), conforme a los mecanismos de control de autenticidad de la cátedra.
- Las flags y contraseñas obtenidas no se publican en texto plano en el repositorio; se reportan mediante su hash SHA-256 (ver Anexo C).
- Horario de trabajo: sin restricción horaria específica, dado que el entorno es un laboratorio aislado sin impacto en sistemas productivos de terceros.

Autorización

Declaro que cuento con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (Docente: Ing. Rodrigo Atilio Elgueta) para realizar las actividades de hacking ético descritas en este informe, en el marco de la Actividad A08, exclusivamente sobre los entornos de laboratorio de TryHackMe indicados en la guía de la actividad.

Metodología utilizada

Se adoptó como referencia metodológica el flujo de trabajo propuesto por la guía de la cátedra, alineado con las fases descritas en **NIST SP 800-115** (*Technical Guide to Information Security Testing and Assessment*): Planeamiento (Pre-engagement), Descubrimiento (Reconocimiento y Escaneo), Ataque (Explotación y Post-explotación) y Reporte. Se eligió este marco por ser una guía técnica de referencia pública, ampliamente utilizada en pentesting profesional, que ordena claramente las fases sin exigir certificación previa, a diferencia de metodologías como OSSTMM. Para la fase de reconocimiento y escaneo se utilizó además el enfoque de enumeración de servicios de OWASP Testing Guide en lo referido a servicios web. Para la sala Vulnversity se incorporó adicionalmente el uso de Burp Suite (módulo Intruder) para la detección de filtros de extensión de archivo del lado del servidor.

3. Durante: Hallazgos por fase

Los hallazgos se presentan agrupados por sala de TryHackMe, para mantener trazabilidad clara entre cada máquina trabajada y sus vulnerabilidades asociadas.

3.1. Hallazgos — Basic Pentesting (Núcleo obligatorio)

Máquina: 10.66.142.44 — ver *bitacora/basic-pentesting/* y *evidencias/explotacion/*, *evidencias/post/*.

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Dentro del home del usuario kay , el archivo de clave privada SSH <code>~/.ssh/id_rsa</code> tenía permisos <code>-rw-r--r--</code> (644), es decir, legible por cualquier usuario del sistema, no solo por su propietario. Esto permitió, estando autenticada como el usuario jan , copiar la clave privada de kay sin necesidad de privilegios de root. Posteriormente, la <i>passphrase</i> que protegía la clave se obtuvo mediante ataque de diccionario offline (John the Ripper + rockyou.txt), permitiendo autenticarse como kay vía SSH sin conocer su contraseña de sistema.
Componente afectado	Permisos de archivo <code>/home/kay/.ssh/id_rsa</code>
Categoría (OWASP / CWE)	CWE-276 (Incorrect Default Permissions)

Campo	Valor
CVE (si aplica)	N/A (error de configuración local, no vulnerabilidad de software)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	<code>ls -la /home/kay/.ssh</code> (permisos 644 en <code>id_rsa</code>); <code>ssh2john</code> + <code>john --wordlist=rockyou.txt</code> (passphrase crackeada); ver <code>bitacora/basic-pentesting/clase_basic-pentesting_04-10.txt</code> y <code>evidencias/explotacion/</code> .
Herramienta utilizada	OpenSSH client, <code>ssh2john</code> , John the Ripper
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir permisos de toda clave privada a 600 (lectura/escritura solo para el propietario); auditar periódicamente permisos en directorios <code>~/.ssh</code> de todos los usuarios; proteger claves privadas con passphrases robustas que sigan la política de contraseñas de la organización.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-02
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Una vez autenticada como el usuario <code>kay</code> (obtenido en H-01), se verificaron sus privilegios con <code>sudo -l</code> . La configuración de <code>sudoers</code> permite a <code>kay</code> ejecutar cualquier comando como cualquier usuario, incluyendo root, sin restricciones ((ALL : ALL) ALL). Esto implica que comprometer la cuenta de <code>kay</code> equivale a obtener control total del servidor (por ejemplo, mediante <code>sudo su</code> o <code>sudo bash</code>).
Componente afectado	Configuración <code>/etc/sudoers</code> para el usuario <code>kay</code>
Categoría (OWASP / CWE)	CWE-250 (Execution with Unnecessary Privileges)
CVE (si aplica)	N/A (error de configuración/política de privilegios)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>sudo -l</code> ejecutado como <code>kay</code> , salida: <code>User kay may run the following commands on ip-10-66-142-44: (ALL : ALL) ALL;</code> ver <code>bitacora/basic-pentesting/clase_basic-pentesting_04-10.txt</code> .

Campo	Valor
Herramienta utilizada	sudo (comando nativo del sistema)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Aplicar el principio de mínimo privilegio: otorgar a kay permisos de sudo únicamente sobre los comandos estrictamente necesarios para sus tareas, en lugar de acceso irrestricto (ALL:ALL). Revisar periódicamente el archivo /etc/sudoers y los grupos con privilegios administrativos.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

3.2. Hallazgos — Vulnversity (Sala de elección)

Máquina: 10.67.128.135 — ver *bitacora/vulnversity/* y *evidencias/* correspondientes.

Campo	Valor
ID del hallazgo	H-03
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Tras enumerar directorios con Gobuster sobre el servidor web en el puerto 3333, se identificó el directorio /internal/ , que exponía un formulario público de carga de archivos (index.php) sin autenticación. Mediante fuzzing de extensiones con Burp Suite Intruder (ataque Sniper) sobre el nombre de archivo, se determinó que el servidor bloqueaba la extensión .php (respuesta “not allowed”) pero no bloqueaba la extensión equivalente .phtml (respuesta “success”), la cual Apache interpreta igualmente como código PHP. Se aprovechó este bypass para subir una reverse shell en PHP (<i>php-reverse-shell</i> , de pentest-monkey, renombrada a .phtml) y ejecutarla accediendo a http://10.67.128.135:3333/internal/uploads/php-reverse-shell.phtml , obteniendo así ejecución remota de comandos (RCE) con el usuario www-data .
Componente afectado	Formulario de carga de archivos en /internal/index.php (filtro de extensiones del servidor web, puerto 3333)
Categoría (OWASP / CWE)	CWE-434 (Unrestricted Upload of File with Dangerous Type) — OWASP Top 10: A04:2021 Insecure Design
CVE (si aplica)	N/A (falla de configuración / lista de bloqueo incompleta, propia de la máquina de laboratorio)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico

Campo	Valor
Evidencia (captura / comando)	Gobuster: directorio <code>/internal/</code> con status 301 (<code>bitacora/vulniversity/gobuster_vulniversity.txt</code>); Burp Intruder: tabla de resultados mostrando <code>.php</code> bloqueado vs. <code>.phtml</code> aceptado; sesión de Netcat (<code>nc -lvnp 1234</code>) con salida <code>uid=33(www-data) gid=33(www-data)</code> ; ver <code>evidencias/explotacion/</code> .
Herramienta utilizada	Gobuster, Burp Suite (Intruder), Netcat, reverse shell PHP (<code>pentestmonkey</code>)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Reemplazar la lista de bloqueo (<i>blacklist</i>) de extensiones por una lista de permitidos (<i>whitelist</i>) estricta; validar el tipo real de archivo por contenido (<i>magic bytes</i> /MIME type) y no solo por extensión; almacenar los archivos subidos fuera del directorio raíz web o con permisos de no ejecución; requerir autenticación para acceder al formulario de carga.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-04
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Tras obtener ejecución de comandos como <code>www-data</code> (H-03), se realizó una búsqueda de binarios con el bit SUID activado (<code>find / -perm -4000 -type f</code>). Se detectó que el binario <code>/bin/systemctl</code> tenía el bit SUID activado, lo cual no corresponde a una configuración estándar de Ubuntu. Esto permitió crear un archivo de unidad de <i>systemd</i> malicioso (<code>ExecStart=/bin/sh -c chmod +s /bin/bash</code>), vincularlo con <code>systemctl link</code> y habilitarlo con <code>systemctl enable --now</code> , ejecutándose con privilegios de root y otorgando el bit SUID a <code>/bin/bash</code> . Esto permitió obtener una shell como root mediante <code>/bin/bash -p</code> , logrando control total del servidor.
Componente afectado	Permisos del binario <code>/bin/systemctl</code> (bit SUID indebido)
Categoría (OWASP / CWE)	CWE-250 (Execution with Unnecessary Privileges)
CVE (si aplica)	N/A (error de configuración local, no vulnerabilidad de software)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico

Campo	Valor
Evidencia (captura / comando)	<code>find / -perm -4000 -type f 2>/dev/null</code> mostrando <code>/bin/systemctl</code> fuera de lugar respecto a los binarios SUID estándar de Ubuntu; creación y habilitación del servicio malicioso; <code>whoami</code> devolviendo <code>root</code> ; flag obtenida en <code>/root/root.txt</code> ; ver <code>bitacora/vulniversity/</code> y <code>evidencias/post/</code> .
Herramienta utilizada	<code>find</code> , <code>systemctl</code> (nativo del sistema, abusado vía SUID)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Eliminar el bit SUID de <code>/bin/systemctl</code> (<code>chmod u-s /bin/systemctl</code>), dado que no requiere dicho permiso para su funcionamiento normal; auditar periódicamente el sistema en busca de binarios SUID no estándar (por ejemplo, con herramientas como <i>linPEAS</i>); aplicar el principio de mínimo privilegio en la asignación de permisos especiales.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	3	H-02, H-03, H-04
Alto	1	H-01
Medio		
Bajo		
Total	4	

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. Corregir permisos de `/home/kay/.ssh/id_rsa` a 600 (prioridad alta, asociado a H-01).
2. Revisar y corregir la entrada de `/etc/sudoers` para `kay`, reemplazando `ALL:ALL` por los comandos mínimos necesarios (prioridad crítica, asociado a H-02).
3. Deshabilitar el directorio `/development/` del servidor web, o restringir su acceso, dado que exponía notas internas con información sensible (nombres de usuario, menciones a versiones de software).
4. Eliminar o proteger el share SMB `Anonymous`, que permitía acceso sin autenticación y filtró el archivo `staff.txt` con nombres de usuarios internos.
5. Reemplazar el filtro de extensiones del formulario de carga de `/internal/` por una lista

blanca estricta y validación por contenido real del archivo (prioridad crítica, asociado a H-03).

6. Quitar el bit SUID de `/bin/systemctl` y auditar el resto de binarios SUID del sistema en busca de configuraciones no estándar (prioridad crítica, asociado a H-04).

Recomendaciones administrativas (políticas y procesos)

1. Implementar una política de contraseñas robusta y verificar su cumplimiento (se detectó que la contraseña de `jan` era débil y cayó ante un diccionario común).
2. Capacitar al personal sobre el uso correcto de claves SSH: generación con passphrase robusta y permisos restrictivos por defecto.
3. Establecer revisiones periódicas (auditorías internas) de la configuración de `sudoers` y de los shares de red disponibles.
4. Concientizar al personal sobre no dejar notas internas con credenciales, nombres de usuario o información sensible en recursos accesibles sin autenticación (web, SMB).
5. Incorporar revisiones de hardening posteriores al despliegue de cualquier servidor (checklist de permisos SUID, filtros de carga de archivos, exposición de formularios sin autenticación) como parte del proceso estándar de puesta en producción.

6. Protocolo de contingencia

Escenario de falla

El escenario de falla más crítico combina los hallazgos H-03 y H-04: un atacante externo que descubra el formulario de carga sin autenticación en `/internal/` puede subir una reverse shell evadiendo el filtro de extensiones (H-03), y desde ahí escalar directamente a privilegios de `root` aprovechando el bit SUID indebido en `/bin/systemctl` (H-04), sin necesidad de credenciales válidas en ningún momento. A esto se suma el escenario descrito para H-02, donde el compromiso de un usuario con permisos `sudo ALL:ALL` también deriva en control total del servidor.

Impacto sobre la continuidad del negocio

Si el servidor comprometido aloja servicios de cara al cliente (web, archivos compartidos vía Samba, proxy Squid), su indisponibilidad afectaría directamente la operatoria de INSECUR S.A.: caída del sitio web corporativo, pérdida de acceso a archivos compartidos del equipo de desarrollo, y posible filtración de información interna (como la expuesta en `/development/`, el share `Anonymous` y el formulario de carga de `/internal/`). El tiempo de afectación dependería de si existen backups actualizados y de la rapidez de detección del incidente; en ausencia de monitoreo activo, el compromiso podría pasar desapercibido durante días.

Plan de respuesta

1. **Activación:** Detección mediante alertas de accesos SSH no habituales, cambios inesperados en archivos del sistema, cargas de archivos ejecutables en formularios web, o reporte de indisponibilidad del servicio por parte de usuarios/clientes.
2. **Contención:** Aislar el servidor de la red (desconectar o bloquear tráfico a nivel de fire-

wall), revocar y rotar inmediatamente las claves SSH y contraseñas de todos los usuarios del sistema, en particular la de **kay**; deshabilitar el formulario de carga comprometido.

3. **Recuperación:** Restaurar el servicio desde el último backup íntegro verificado previo al incidente; reinstalar el sistema desde una imagen limpia si se confirma presencia de malware o persistencia del atacante.
4. **Comunicación:** Notificar de inmediato al responsable de sistemas/CTO de INSECUR S.A.; informar a clientes afectados si hubo exposición de datos; evaluar obligación de notificación a autoridades según la normativa de protección de datos vigente.
5. **Post-mortem:** Documentar la cronología del incidente, causa raíz (en este caso, permisos incorrectos en `id_rsa`, política de `sudoers` permisiva, filtro de extensiones incompleto y SUID indebido en `systemctl`), y actualizar el plan de contingencia y las políticas de hardening en base a lo aprendido.

RTO y RPO estimados

RTO (Recovery Time Objective): 4 horas (tiempo máximo tolerable para restaurar el servicio web/Samba antes de impacto serio en el negocio, considerando que hay backup disponible).

RPO (Recovery Point Objective): 24 horas (la pérdida de datos generada por la restauración desde el último backup no debe superar 1 día, dado que los archivos compartidos son críticos para el equipo de desarrollo).

7. Anexos

Anexo A — Bitácora de comandos

Archivos de bitácora organizados por sala:

- `bitacora/basic-pentesting/` — clase narrativa completa, `nmap`, `gobuster`, `enum4linux`, `hydra` y acceso SMB anónimo.
- `bitacora/vulniversity/` — clase narrativa completa, `nmap` (`-sV` y `-p-`), `gobuster`, fuzzing de extensiones con Burp Intruder, reverse shell y enumeración de binarios SUID (`suid_files.txt`).

Anexo B — Capturas de pantalla

Carpeta `evidencias/` con subcarpetas por fase. Cada archivo nombrado como `<fase>_<hallazgoID>.png`.

Anexo C — Hashes de las flags obtenidas

```
# Formato: identificador sha256_hash

--- Pentesting Fundamentals ---
Respuesta final
583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6

--- Basic Pentesting ---
Contraseña de jan (hydra)
9eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae617
```

```
Passphrase clave privada de kay
873504f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a08

Contrasena final (pass.bak de kay)
3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57

--- Vulniversity ---
User flag (www-data -> /home/bill/user.txt)
d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956

Root flag (/root/root.txt)
cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8
```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante

Fecha

8. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- TryHackMe. *Vulniversity*: [sala oficial](#)
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- pentestmonkey. *php-reverse-shell*: [repositorio oficial](#)